



[BIT703 Web Technologies](#) / [Contents](#) / Topic 10: Server-side web application development with procedural and object-oriented database programming / Database operations in PHP

CRUD: Create 10m

The **create** operation performs the **insert in SQL** function, used to create new records. The following example shows how to insert new records into the database. You must execute an **insert** statement against the data to insert data into the database. This example uses a prepared statement to set up the data. This is the preferred method for SQL, as it prevents potential SQL injection attacks. We will briefly cover this topic later in this section.

Watch What are SQL injections? // Explained in 180 seconds (Cybr, 2024) (4:07) for a quick summary of how these attacks work and how they can be protected against.



ENTER FULLSCREEN

[Skip to main content](#)

SQL Injections? // Explained in 180 seconds



No transcript available.

Powered by  3PLAYMEDIA



[Skip to main content](#)

Use this approach with any SQL you are using for information sent via an HTML form. It works by creating placeholders for the fields to be inserted (defined by the appropriate number of question marks in the VALUES clause). The value of variables becomes bound when the statement completes.

The MySQLi functions used in the next example for inserting a new record into the database are:

- **mysqli_prepare(mysqli \$mysql, string \$query) or mysqli::prepare(string \$query)** – prepares the SQL query and returns a statement handle to be used for further operations on the statement. The query must consist of a single SQL statement.
- **mysqli_stmt_bind_param(mysqli_stmt \$statement, string \$types, ...) or mysqli_stmt::bind_param(string \$types, ...)** – binds variables for the parameter markers in the prepared SQL statement. The types of each field can be 'i' (integer), 'd' (double), 's' (string) or 'b' (blob – binary large object).
- **mysqli_stmt_execute(\$stmt) or mysqli_stmt::execute()** – executes a previously prepared statement.
- **mysqli_stmt_close(mysqli_stmt \$statement) or mysqli_stmt::close()** – closes a prepared statement.

Note that some HTML has been added at the end to indicate that the action has taken place.

You can confirm if the insert was successful by opening the PHP page that runs the select query and looking at the data displayed.



Copy

[Skip to main content](#)

```
1  <?php
2  class FormData {
3      public $name;
4      public $address;
5      public $category;
6      __construct($_name,$address,$_category) {
7          $self->name = $_name;
8          $self->address = $_address;
9          $self->category = $_category;
10     }
11 }
12     $R = new FormData("SWEET PANCAKES","345 BROADWAY ROAD","DESSERT");
13 // assume data validation has been done
14 // prepare the query and make provision for the variable data (?) place holders
15     $query = "INSERT INTO tbl_restaurant (resta_name, resta_address, resta_category) VAL
16     $stmt = mysqli_prepare($db_connection, $query); //prepare the query
17 // bind the 3 strings to the values from above
18     mysqli_stmt_bind_param($stmt, 'sss', $R->name, $R->address, $R->category); //associa
19     mysqli_stmt_execute($stmt);
20     mysqli_stmt_close($stmt);
21     echo "<p>data inserted</p>";
22 ?>
```

gistfile1.txt hosted with ❤ by GitHub

[view raw](#)

Thoughts on this page?

